

Especificação de confiabilidade e segurança

Paulo C. Masiero
Livro Sommerville

Aeroporto de Varsóvia, Polônia (1993)

- Um avião aterrissou no aeroporto Varsóvia durante uma tempestade.
- Por 9s após a aterrissagem os sistemas de freios, controlado por computador, não funcionaram.
- O sistema não havia reconhecido que o avião já havia pousado (falha) e assumiu que ele ainda estava no ar.
- Uma ferramenta de segurança garantiu que o sistema não habilitasse o reversor de empuxo, pois seria perigoso caso isso fosse feito no ar.
- O Avião seguiu em direção a um banco de areia e pegou fogo.

Aeroporto de Varsóvia, Polônia (1993)



Aeroporto de Varsóvia, Polônia (1993)

- O inquérito sobre o acidente mostrou que o sistema havia funcionado de acordo com a especificação.
- Não havia erros no programa.
- Qual foi o problema então?
- A especificação do sistema estava incompleta e uma situação rara não foi levada em conta.

Requisitos de confiabilidade e segurança

- Confiabilidade não depende apenas de bom trabalho de engenharia.
- Requer atenção aos detalhes ao elicitar os requisitos.
- Requisitos adicionais em relação à confiabilidade e segurança devem ser incluídos na especificação.

Requisitos de confiabilidade e segurança

- Requisitos funcionais: definem a verificação e os recursos de recuperação do sistema e proteção contra falhas e ataques de sistema externos (requisitos “não deve”).
 - *E.g.*: “O sistema **não deve** permitir que o reversor seja ligado se o avião estiver voando”
- Requisitos não-funcionais: garantem a confiabilidade e a disponibilidade requerida do sistema.

Exemplos

- O sistema não deve permitir que os usuários modifiquem senhas de acesso a arquivos que eles não criaram (proteção).
- O sistema não deve permitir o modo reverso de empuxo quando a aeronave estiver em voo (segurança).
- O sistema não deve permitir a ativação simultânea de mais de 3 sinais de alarme (segurança).

Abordagem baseada em riscos

- Como descobrir os requisitos de segurança e confiabilidade?
 - Abordagem baseada em riscos
- É necessário identificar e classificar as catástrofes que causarão os eventos, incluindo suas probabilidades de ocorrência
- Gerar requisitos que deverão impedir ou, pelo menos, minimizar os problemas de maior ocorrência e aqueles que, mesmo improváveis, causarão danos graves.

Abordagem baseada em riscos

Especificação dirigida a riscos



Fonte: Sommerville, 2011

I - Identificação dos riscos

- Os riscos do sistema são identificados
- Depende apenas do meio em que a aplicação será implementada (independente da tecnologia utilizada)

II - Análise dos riscos e classificação

- Cada risco é considerado separadamente.
- Aqueles que são potencialmente perigosos e não são improváveis são selecionados para análise futura.
- Neste estágio, riscos que são improváveis ou não podem ser detectados pelo sistema são eliminados.
 - Ex.: reação alérgica causada por sistema de bombeamento de insulina

III - Decomposição de riscos

- Cada risco tem sua causa identificada.
- As causas podem ser problemas no hardware, no software ou herdadas de falhas no projeto.

IV – Redução de riscos

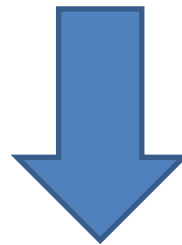
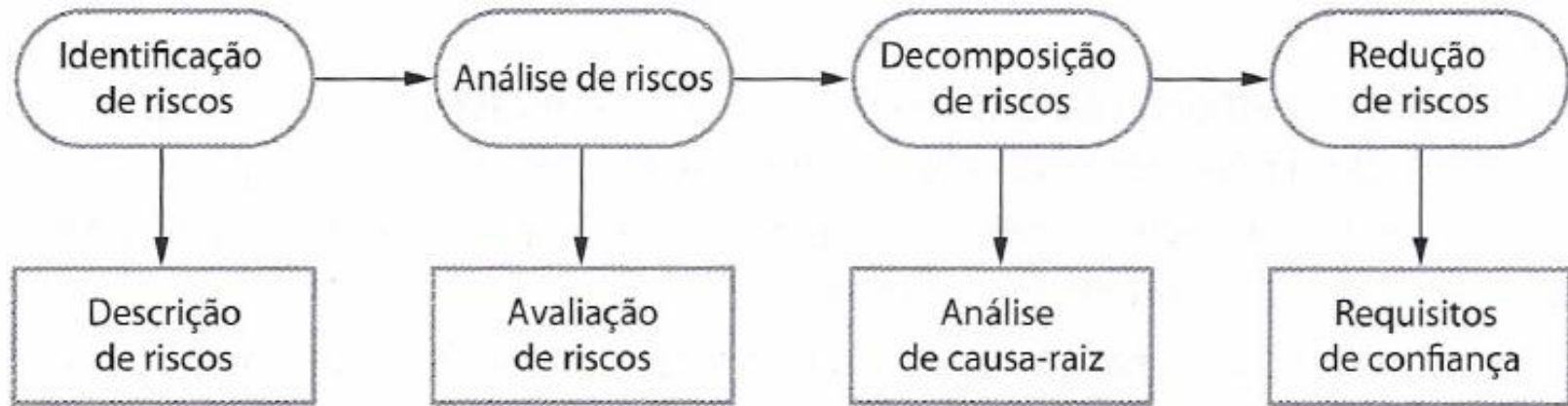
- Propor maneiras para redução ou eliminação dos riscos
- Esta etapa gera requisitos de confiabilidade

Etapas adicionais (p/ grandes sistemas)

- A análise de risco pode ser dividida em três partes:
 - Análise preliminar:
 - Análise de ciclo de vida: dos riscos que aparecem com as decisões de projeto.
 - Análise de risco operacional: dos riscos envolvendo a interface com usuário e os resultantes de erros do operador.
- Exemplo (segurança): os usuários devem identificar-se com uma sequência de palavras, pois são mais seguras. Entretanto, decide-se usar um sistema existente que apenas permite o uso de senha.
 - O requisito não é satisfeito e seria necessário incluir alguma funcionalidade adicional para compensar o aumento de risco por usar senhas.

Abordagem baseada em riscos

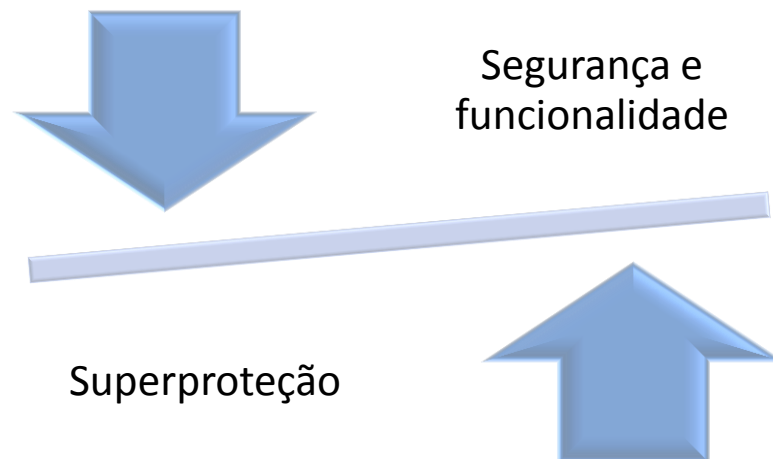
Especificação dirigida a riscos



**Todas as etapas são importantes!
É impossível tomar todas as decisões de
segurança e confiabilidade sem conhecimento
total do sistema.**

Especificação de segurança

- Sistemas de segurança crítica são sistemas cujas falhas podem causar danos ou morte aos seus usuários.
- Os seus requisitos geralmente não estão relacionados com os requisitos comuns do sistemas (requisitos de proteção).
- Baseada na busca por perigos.



Especificação de segurança

Mapeada na abordagem
baseada em riscos

Identificação
dos perigos



Avaliação
dos perigos



Análise dos
perigos



Redução dos
riscos

I - Identificação dos perigos

- Listar todos os perigos envolvidos no problema com ajuda de especialista da área.
- Classificá-los de acordo com seu tipo (elétrico, biológico, físico, falha no sistema, *etc.*).
- Técnicas em grupo como *brainstorm* são utilizadas.
- *Exemplos (sistema bombeador de insulina):*
 - *Envio de quantidade demasiada de insulina (falha no sistema)*
 - *Envio de quantidade abaixo do esperado de insulina (falha no sistema)*
 - *Reação alérgica ao equipamento (biológico)*
 - *Fim da bateria (elétrico)*

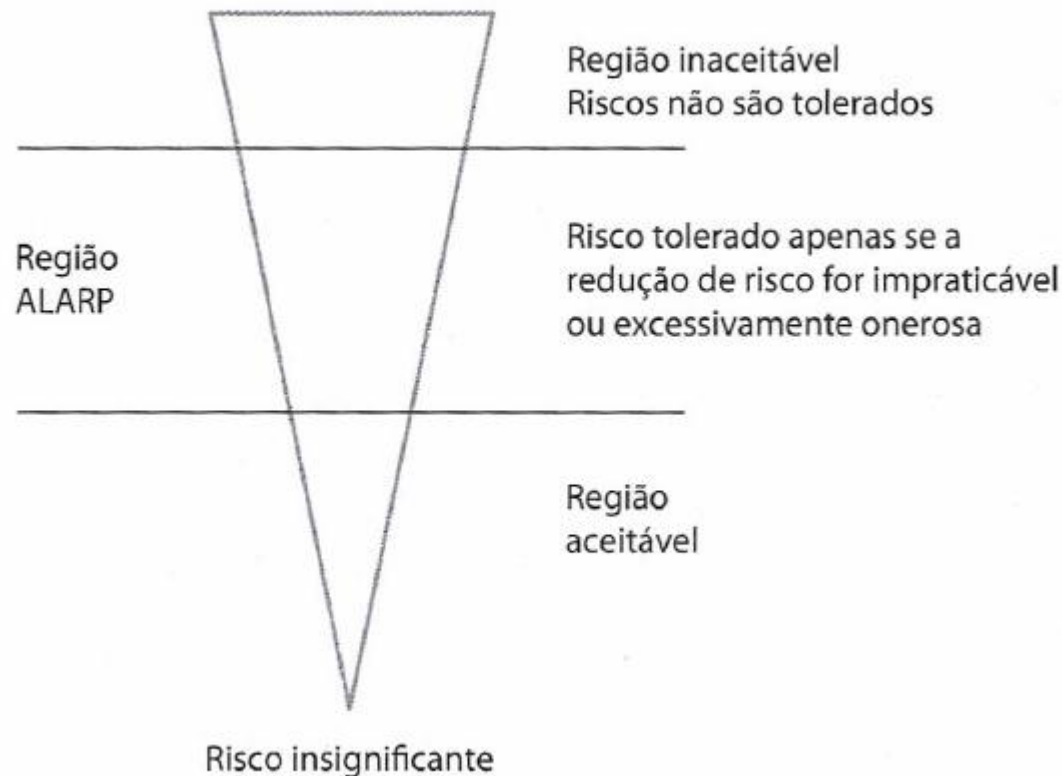
II - Avaliação dos perigos

- Riscos não toleráveis: estão ligados aos risco de (perda de) vida dos seres envolvidos.
 - O sistema deve garantir que esses eventos não ocorram.
- ALARP (*As low as reasonably practical*): são riscos com consequências menores ou com baixíssimas chances de ocorrer se tiverem consequências graves.
 - Análises de custos e viabilidade devem ser feitas
- Riscos aceitáveis: são riscos que não afetam em nada o sistema
 - Os projetistas devem minimizar a quantidade de riscos aceitáveis, contanto que não afete significativamente os gastos, tempo de entrega ou outros requisitos funcionais

II - Avaliação dos perigos

Análise das consequências e probabilidades de eventos perigosos ocorrerem.

O triângulo de risco



II - Avaliação dos perigos

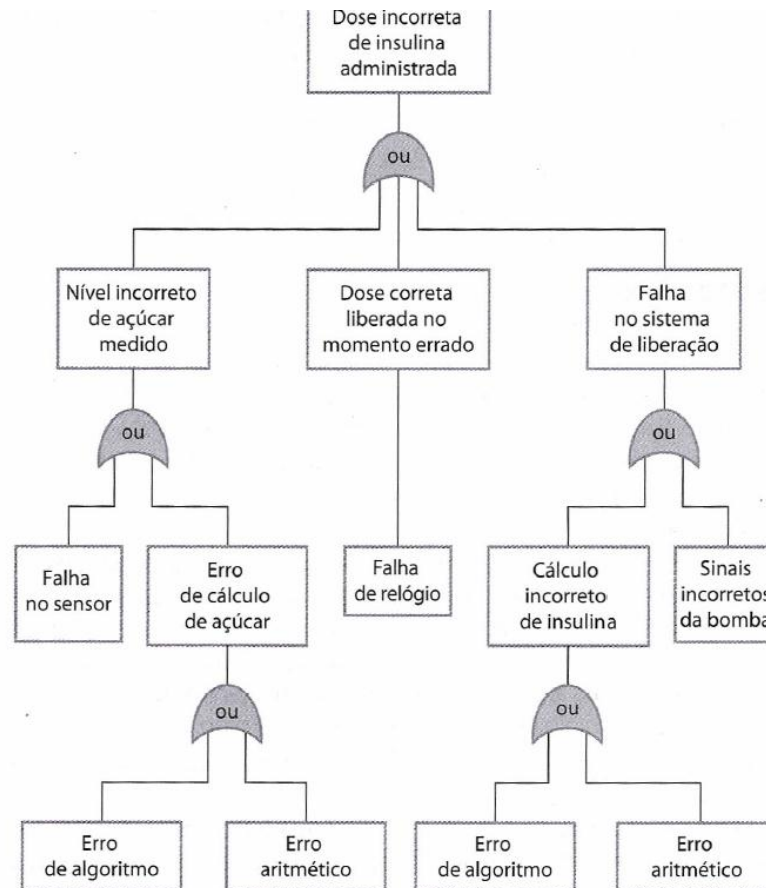
Tabela 12.1 Classificação de riscos para a bomba de insulina

Perigo identificado	Probabilidade de perigo	Severidade de acidente	Risco estimado	Aceitabilidade
1. Cálculo de overdose de insulina	Média	Alta	Alto	Intolerável
2. Cálculo de dose insuficiente de insulina	Média	Baixa	Baixo	Aceitável
3. Falha de sistema de monitoramento de hardware	Média	Média	Baixo	ALARP
4. Falha de energia	Alta	Baixa	Baixo	Aceitável
5. Máquina ajustada incorretamente	Alta	Alta	Alto	Intolerável
6. Quebra de máquina no paciente	Baixa	Alta	Médio	ALARP
7. Máquina causa infecção	Média	Média	Médio	ALARP
8. Interferência elétrica	Baixa	Alta	Médio	ALARP
9. Reação alérgica	Baixa	Baixa	Baixo	Aceitável

III – Análise de perigos

- Encontrar as causas originais dos perigos.
- Podem ser empregadas abordagens *top-down* (intuitivas) ou *bottom-top* (indutivas).
- Várias técnicas podem ser utilizadas.
 - Redes de Petri (Peterson, 1981)
 - Lógica formal (Jahanian & Mok, 1986)
 - Árvores de falhas (Leveson & Stolzy, 1987)

III – Análise dos perigos – Sistema bombeador de insulina



IV – Redução dos riscos

- Neste estágio, os perigos já foram identificados, avaliados e analisados. Resta “apenas” a solução.
- Existem três abordagens distintas
 - Evitar o perigo
 - Detecção e remoção de perigo
 - Limitação de danos
- Normalmente é utilizada uma combinação das três abordagens.

IV – Redução dos riscos – Sistema bombeador de insulina

- Erros aritméticos
 - Alguma operação matemática leva a uma inconsistência.
 - Gerar exceção e tratá-la.
 - Levar o sistema a um estado seguro (desligado).
- Erros no algoritmo
 - Mais difícil de ser tratado, pois não existe exceção clara a ser tratada.
 - Poderia ser resolvido comparando medidas anteriores e percebendo alguma discrepância.

12.3 – Especificação de confiabilidade

- Segurança e proteção → Evitar situações indesejadas
- Confiabilidade → Limitar situações indesejadas
 - É possível especificar o nível de confiabilidade do sistema.
- Dependências
 - Confiabilidade do hardware
 - Confiabilidade do software
 - Confiabilidade dos operadores
- Requisitos de confiabilidade devem
 - Compensar falhas de software
 - Ajudar a detectar e recuperar o sistema após falhas de hardware ou erros do operador.

12.3 – Especificação de confiabilidade

- Processo de especificação de confiabilidade
 - Identificação dos riscos
 - Identificar os tipos de falhas no sistema que podem acarretar alguma perda econômica.
 - Analise dos riscos
 - Estimar os custos e consequências dos diferentes tipos de falhas.
 - Selecionar as falhas mais graves para análise posterior.
 - Decomposição dos riscos
 - Analisar a raiz da causa da provável falha.

12.3 – Especificação de confiabilidade

- Processo de especificação de confiabilidade
 - Redução dos riscos
 - Deve-se estabelecer as probabilidades aceitáveis dos diferentes tipos de falhas, levando em conta os custos de cada falha.

12.3.1 – Indicadores de confiabilidade

- Probabilidade de falha sob demanda (POFOD)
 - Probabilidade de ocorrer uma falha durante um ciclo do sistema.
 - Ex.: $POFOD = 0.001$ significa que existe 1 chance em 1000 de ocorrer uma determinada falha durante uma execução do sistema.
- Taxa de ocorrência de falhas (ROCOF)
 - Número provável de falhas no sistema relativo a um determinado período de tempo ou um determinado número de execuções do sistema.
 - Ex.: $ROCOF = 1/1000$ significa que em 1000 execuções do sistema, apenas uma falha ocorrerá.

12.3.1 – Indicadores de confiabilidade

- Disponibilidade (AVAIL)
 - Probabilidade do sistema estar operando quando é requisitado um serviço.
 - Ex.: AVAIL= 0.9999 significa que o sistema estará disponível, em média, durante 99,99% do tempo de operação.
- Tempo médio entre falhas (MTTF)
 - Unidade de tempo média entre falhas no sistema.
 - Ex.: MTTF = 30min significa que a cada meia hora ocorrerá uma falha.

12.3.1 – Indicadores de confiabilidade

- Para avaliar a confiança do sistema é necessário obter dados da sua operação.
- Ex.:
 - O número de falhas dos sistema dado um número de pedidos de serviço ao sistema.
 - Utilizado para medir a probabilidade de falha na demanda (POFOD).
 - O tempo ou o número de transações entre falhas no sistema.
 - Utilizado para medir a taxa de ocorrência de falhas (ROCOF) e o tempo médio entre falhas (MTTF).
 - O tempo para restaurar ou reiniciar o sistema após uma falha que leva a perda de serviço.
 - Utilizado para medir a disponibilidade do sistema (AVAIL).

12.3.2 – Requisitos de confiabilidade não funcionais

- Envolve especificações quantitativas dos requisitos de confiabilidade e disponibilidade do sistema.
- Vantagens:
 - Decidir o nível de confiabilidade do sistema, mostrando o que realmente é necessário.
 - Fornece uma base para avaliar quando os testes no sistema podem ser interrompidos (assim que o nível de confiabilidade de cada requisito for atingido).
 - É uma forma de avaliar qual estratégia de projeto (design) melhora a confiabilidade do sistema.
 - Certificação do sistema.

12.3.2 – Requisitos de confiabilidade não funcionais

- Dificuldade:
 - Traduzir experiências práticas em especificações quantitativas.
 - Custos para testar.
 - Ex.:
 1. $POFOD = 0.0001$. Então são necessários cerca de 50 mil testes para verificar se o POFOD de determinada falha realmente é 0.0001.
 2. 1 000 cópias do sistema são instaladas e o sistema executa 1 000 vezes por segundo. O sistema não pode falhar uma única vez.

12.3.2 – Requisitos de confiabilidade não funcionais

- Passos para evitar especificação excessiva (superestimada)
 - Especificar os requisitos de disponibilidade e confiabilidade para diferentes tipos de falhas → menor probabilidade de ocorrência de falhas graves.
 - Especificar separadamente os requisitos de disponibilidade e confiabilidade. Falhas que afetam os serviços mais críticos devem ser especificados como menos prováveis.
 - Decidir quando é necessário melhorar a confiabilidade e quando pode-se atingir os objetivos de outra maneira.
 - Ex.: Um sistema de ATMs pode investir altos valores para evitar falhas durante certas operações que poderiam ser apenas canceladas a partir de análises de segurança baseada na experiência adquirida pelos bancos.

12.3.3 – Requisitos de confiabilidade funcionais

- Envolve identificar os requisitos que definem restrições e características que contribuem para a confiabilidade do sistema.
- Há três tipos:
 1. Requisitos de checagem
 - Restrições nas portas de entrada do sistema para evitar valores incorretos ou fora da zona de valores permitidos.
 2. Requisitos de recuperação
 - Devem ajudar na recuperação do sistema após uma falha
 3. Requisitos de redundância
 - Implicam em redundâncias no sistema para que uma falha isolada não gere uma perda total do serviço.

12.3.3 – Requisitos de confiabilidade funcionais

- Exemplos:
 - RR1: Um intervalo de valores deve ser definido para todas as entradas dos operadores. (Requisito de checagem)
 - RR2: Cópias do banco de dados dos pacientes devem ser mantidas em dois servidores separados que não estejam no mesmo prédio. (Requisito de restauração e requisito de redundância)

12.4 – Especificações de proteção

- Semelhanças com especificações de segurança
 - É impraticável especificar quantitativamente.
 - Deve-se usar “não deve” na elaboração dos requisitos.
- Diferenças:
 - Ataques ao sistema são planejados e o invasor pode conhecer os pontos fracos do sistema.
 - Encontrar a raiz do ataque pode ser difícil, uma vez que ela pode ter sido ocultada.
 - Desligar o sistema, na maioria das vezes, significa que o ataque foi bem sucedido.
 - O invasor pode realizar ataques diferentes, aprimorando-se à medida que começa a conhecer mais o sistema.

12.4 – Especificações de proteção

- 10 tipos de requisitos de proteção (Firesmith - 2003)
 1. Requisitos de identificação
 - Especifica quando um sistema deve identificar o usuário que irá interagir com ele.
 2. Requisitos de autenticação
 - Especifica como um usuário deve ser identificado.
 3. Requisitos de autorização
 - Especifica os privilégios e permissões de acesso de um usuário identificado.

12.4 – Especificações de proteção

4. Requisitos de imunidade

- Especifica como um sistema deve se proteger contra vírus, worms e ameaças similares.

5. Requisitos de integridade

- Especifica como a corrupção dos dados pode ser evitada.

6. Requisitos de detecção de intrusão

- Especifica quais mecanismos devem ser usados para detectar ataques ao sistema.

7. Requisitos de não repúdio

- Especifica que uma parte, quando participa de uma transação, não pode negar sua participação na transação.

12.4 – Especificações de proteção

8. Requisitos de privacidade

- Especifica como a privacidade dos dados será mantida.

9. Requisitos de auditoria de proteção

- Especifica como o uso do sistema pode ser auditado e verificado.

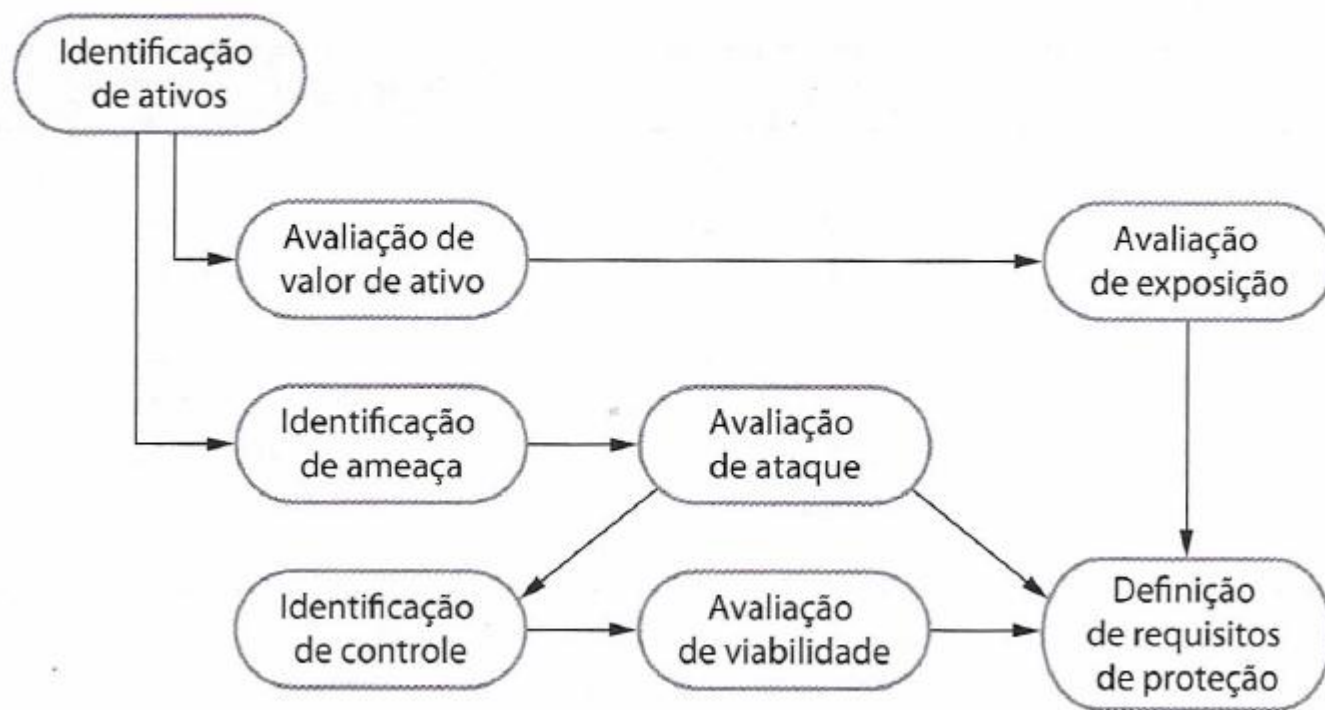
10. Requisitos de proteção de manutenção de sistema

- Especifica como um aplicativo pode prevenir que alterações autorizadas comprometam, acidentalmente, seus mecanismos de proteção.

12.4 – Especificações de proteção

- Estágios do processo:
 - Processo de avaliação e análise de riscos são variações do processo de especificações genéricas da abordagem baseada em riscos.

O processo de avaliação preliminar de riscos para requisitos de proteção



12.4 – Especificações de proteção

- Estágios do processo:
 1. Identificação (Identificação de riscos)
 - Identifica os ativos do sistema que requerem proteção.
 2. Avaliação de valor de ativo (Análise de risco)
 - Estimar o valor de um ativo identificado.
 3. Avaliação de exposição (Análise de riscos)
 - Avaliar a perda em potencial associada a cada ativo.
 4. Identificação de ameaça (Análise de risco)
 - Identificar as ameaças aos ativos do sistema.

12.4 – Especificações de proteção

5. Avaliação de ataques (Decomposição e riscos)
 - Decompor cada ameaça em ataques que o sistema pode sofrer e as possíveis maneiras como o ataque pode ocorrer.
6. Identificação de Controle (Redução de risco)
 - Propor os controles que podem ser instalados para proteger os ativos (Ex. criptografia).
7. Avaliação de viabilidade (Redução de risco)
 - Avaliar a viabilidade técnica e os custos dos controles propostos.
8. Definição de requisitos de proteção (Redução de risco)
 - Formular os requisitos de proteção do sistema utilizando os conhecimentos da exposição do sistema, das ameaças e da avaliação de controle.

12.4 – Especificações de proteção

- Exemplo: Sistema de informação (Hospital para saúde mental)
 - Requisitos de proteção
 1. Informações sobre o paciente devem ser baixadas do banco de dados para uma área segura no computador do consultório no início de cada consulta.
 2. Todas as informações referentes aos pacientes devem ser criptografadas.
 3. As informações sobre o paciente devem ser atualizadas no banco de dados e então apagadas do computador do consultório no fim de cada consulta.
 4. Um registro de todas as alterações feitas no banco de dados do sistema e quem as fez deve ser mantido em um computador que não seja o mesmo onde está o banco de dados.